



Information Security Policy

ISMS Security Policy Documentation	تصنيف الوثيقة
ISMS-DOC-04-1	مرجع الوثيقة
1	الإصدار
12 September 2026	التاريخ
سارة الحربي - CISO	مؤلف الوثيقة
بنك الآفاق الرقمي	مالك الوثيقة

سجل المراجعة

الإصدار	التاريخ	مُجري التعديل	ملخص التعديلات
1	2026/09/12	سارة الحربي - CISO	الإصدار الأول لوثيقة تحديد نطاق نظام أمن المعلومات (ISMS)

توزيع

الاسم	المنصب
سارة الحربي	مدير أمن المعلومات (CISO)
فهد العتيبي	مدير تقنية المعلومات (CIO)
نورة القحطاني	الرئيس التنفيذي (CEO)
عبد الله المحيسن	رئيس مجلس الإدارة

موافقة

الاسم	الموقع	التوقيع	التاريخ
سارة الحربي	مدير أمن المعلومات (CISO)		
فهد العتيبي	مدير تقنية المعلومات (CIO)		
نورة القحطاني	الرئيس التنفيذي (CEO)		
عبد الله المحيسن	رئيس مجلس الإدارة		

1 المقدمة

تحدد هذه الوثيقة سياسة أمن المعلومات الخاصة ببنك الأفاق الرقمية.

بصفته مؤسسة مالية رائدة وتتطلع نحو المستقبل، يدرك بنك الأفاق الرقمية على أعلى المستويات الإدارية ضرورة ضمان استمرار أعماله بسلاسة ودون انقطاع لصالح عملائه ومساهميهم وأصحاب المصلحة الآخرين، خصوصاً في ظل المنافسة المتزايدة من البنوك الرقمية الجديدة واعتماد العملاء المتزايد على الخدمات المصرفية الرقمية.

ولتوفير هذا المستوى من التشغيل المستمر، قام بنك الأفاق الرقمية بتطبيق نظام إدارة أمن المعلومات (ISMS) بما يتماشى مع المعيار الدولي لأمن المعلومات ISO/IEC 27001:2022. بحيث يحدد هذا المعيار متطلبات نظام إدارة أمن المعلومات استناداً إلى أفضل الممارسات المعترف بها دولياً.

يحقق تنفيذ نظام إدارة أمن المعلومات فوائد عديدة للبنك، من أبرزها:

- حماية تدفقات الإيرادات وربحية البنك، خاصة في ظل الاستثمارات المتنامية في التقنية المالية.
- ضمان استمرارية تقديم الخدمات المصرفية الرقمية والتقليدية للعملاء دون انقطاع.
- الحفاظ على قيمة المساهمين وتعزيز ثقتهم في إدارة البنك للمخاطر السيبرانية.
- الامتثال للمتطلبات القانونية والتنظيمية الصادرة عن البنك المركزي السعودي (ساما) وهيئة البيانات والذكاء الاصطناعي (سدأيا).

قرر بنك الأفاق الرقمية الحصول على الشهادة الكاملة لمعيار ISO/IEC 27001 حتى يتم التحقق من التنبؤ الفعّال لأفضل ممارسات أمن المعلومات من قبل طرف ثالث مستقل (جهة اعتماد معتمدة)، تماشياً مع توجهات البنك المركزي السعودي الذي يعتبر هذه الشهادة أحد المتطلبات الأساسية أو المساعدات القوية للامتثال.

تتطبق هذه السياسة على جميع الأنظمة والأفراد والعمليات التي تشكل أنظمة معلومات البنك، بما يشمل أعضاء مجلس الإدارة، المدراء، الموظفين، الموردين، والأطراف الثالثة الأخرى التي لديها وصول إلى أنظمة بنك الأفاق الرقمية، سواء في المقر الرئيسي بالرياض، أو في مركز التعافي من الكوارث بجدة، أو في أي من الفروع المصرفية الـ 25.

ترتبط بهذه السياسة الوثائق الداعمة التالية التي توفر معلومات إضافية حول كيفية تطبيقها:

- منهجية تقييم ومعالجة المخاطر
- بيان قابلية التطبيق (Statement of Applicability)
- سياسة التحكم في الوصول
- سياسة تشفير البيانات
- سياسة الأمن المادي (Hardware Security)
- سياسة مكافحة البرمجيات الخبيثة
- سياسة النسخ الاحتياطي
- سياسة التسجيل والمراقبة
- سياسة إدارة الثغرات التقنية
- سياسة أمن الشبكات
- سياسة التطوير الأمن
- سياسة أمن المعلومات لعلاقات الموردين
- سياسة إدارة التوافر واستمرارية الأعمال
- سياسة الخصوصية وحماية البيانات الشخصية

- سياسة أمن الموارد البشرية
 - إجراء إدارة الحوادث الأمنية
- تفاصيل آخر إصدار لكل من هذه الوثائق متاحة من خلال سجل توثيق نظام إدارة أمن المعلومات.

2 سياسة أمن المعلومات

2.1 متطلبات أمن المعلومات

سيتم الاتفاق على تعريف واضح لمتطلبات أمن المعلومات داخل بنك الأفاق الرقمية والحفاظ عليه بالتنسيق مع إدارات الأعمال الداخلية، بحيث يكون كل نشاط ضمن نظام إدارة أمن المعلومات موجهاً نحو تحقيق تلك المتطلبات. سيتم أيضاً توثيق المتطلبات النظامية والتنظيمية والتعاقدية — وعلى رأسها متطلبات البنك المركزي السعودي (ساما) الخاصة بإطار الأمن السيبراني، ونظام حماية البيانات الشخصية الصادر عن هيئة البيانات والذكاء الاصطناعي (سدابا)، وأنظمة مكافحة غسل الأموال وتمويل الإرهاب — وإدخالها في عملية التخطيط.

ستُنقِط المتطلبات الخاصة بأمن الأنظمة أو الخدمات الجديدة أو المُعدلة كجزء من مرحلة التصميم في كل مشروع، بما يشمل مشاريع تطوير تطبيق آفاق بلس ومنصة آفاق نت.

من المبادئ الأساسية لنظام إدارة أمن المعلومات في بنك الأفاق الرقمية أن تكون الضوابط المطبقة مدفوعة باحتياجات الأعمال، وسيتم توصيل ذلك بانتظام لجميع الموظفين من خلال اجتماعات الفرق ووثائق التوعية، مع مراعاة التحدي الثقافي المتمثل في أن بعض الموظفين القدامى قد يرون إجراءات الأمن عائقاً لسرعة العمل، وضرورة ترسيخ ثقافة "الأمن أولاً" تدريجياً بدعم من الإدارة العليا.

2.2 إطار عمل تحقيق الأهداف

سيُستخدم دور منتظم لتحديد أهداف أمن المعلومات، بحيث يتزامن مع دورة تخطيط الميزانية السنوية لأمن المعلومات (الحالية 12 مليون ريال سعودي والمتوقع ارتفاعها إلى 18 مليون ريال بعد التطبيق الكامل للنظام). سيضمن ذلك الحصول على التمويل الكافي لأنشطة التحسين المحددة.

ستستند هذه الأهداف إلى فهم واضح لمتطلبات الأعمال، مستنيرة بعملية مراجعة الإدارة التي قد يتم خلالها الحصول على آراء الأطراف المعنية ذات الصلة (مجلس الإدارة، العملاء، البنك المركزي، الموردون، وغيرهم كما ورد في سجل الأطراف المعنية).

سيتم توثيق أهداف أمن المعلومات لفترة زمنية متفق عليها، مع تفاصيل حول كيفية تحقيقها. سيتم تقييمها ومراقبتها كجزء من مراجعات الإدارة للتأكد من استمرار صلاحيتها. في حال لزم إجراء تعديلات، ستتم إدارتها من خلال عملية إدارة التغيير.

وفقاً لمعيار ISO/IEC 27001، سيتم اعتماد ضوابط Annex A من المعيار حيثما كان ذلك مناسباً من قبل بنك الأفاق الرقمية. سيتم مراجعة هذه الضوابط بانتظام في ضوء نتائج تقييمات المخاطر وبما يتماشى مع خطط معالجة مخاطر أمن المعلومات. لتفاصيل الضوابط المطبقة والمستبعدة من Annex A ، يُرجى الرجوع إلى بيان قابلية التطبيق (Statement of Applicability).

بالإضافة إلى ذلك، سيتم اعتماد وتطبيق ضوابط معززة وإضافية من مدونات الممارسات التالية حيثما كان ذلك مناسباً:

- ISO/IEC 27002 — مدونة ممارسات لضوابط أمن المعلومات
- ISO/IEC 27017 — مدونة ممارسات لضوابط أمن المعلومات الخاصة بالخدمات السحابية، وهي ذات أهمية خاصة نظراً لاستخدام البنك لخدمات Amazon Web Services
- ISO/IEC 27018 — مدونة ممارسات لحماية المعلومات الشخصية القابلة للتحديد (PII) لدى مزودي الخدمات السحابية

سيوفر تبني هذه المدونات ضماناً إضافياً لعملائنا ويساعد بشكل أكبر في الامتثال لتشريعات حماية البيانات المحلية والدولية.

2.3 التحسين المستمر لنظام إدارة أمن المعلومات

تتمثل سياسة بنك الأفاق الرقمية فيما يتعلق بالتحسين المستمر فيما يلي:

- التحسين المستمر لفعالية نظام إدارة أمن المعلومات.
- تعزيز العمليات الحالية لتتوافق مع الممارسات الجيدة المحددة في معيار ISO/IEC 27001 والمعايير ذات الصلة.
- الحصول على شهادة ISO/IEC 27001 والحفاظ عليها بشكل مستمر.
- رفع مستوى الاستباقية (وتصور الأطراف المعنية لهذه الاستباقية) فيما يتعلق بأمن المعلومات، خصوصاً بعد الحوادث السابقة الموثقة (انقطاع الخدمة، التصيد الاحتيالي، فقدان الجهاز المحمول، انتهاء شهادة TLS، الصلاحيات غير المراجعة).
- جعل عمليات وضوابط أمن المعلومات أكثر قابلية للقياس لتوفير أساس سليم لاتخاذ القرارات المستنيرة.
- مراجعة المقاييس ذات الصلة سنوياً لتقييم مدى ملاءمة تغييرها، استناداً إلى البيانات التاريخية المُجمّعة.
- الحصول على أفكار للتحسين من خلال اجتماعات دورية وأشكال أخرى من التواصل مع الأطراف المعنية.
- مراجعة أفكار التحسين في اجتماعات الإدارة الدورية لتحديد الأولويات وتقييم الجداول الزمنية والفوائد.
- يمكن الحصول على أفكار التحسين من أي مصدر، بما يشمل الموظفين والعلماء والموردين وموظفي تقنية المعلومات وتقييمات المخاطر وتقارير الخدمة ونتائج فحوصات الثغرات ومحاكاة التصيد الاحتيالي. وبمجرد تحديدها، سيتم تسجيلها وتقييمها كجزء من مراجعات الإدارة.

2.4 مجالات سياسة أمن المعلومات

يُحدد بنك الأفاق الرقمية سياسته في مجموعة واسعة من المجالات المتعلقة بأمن المعلومات، والموصوفة بالتفصيل في مجموعة شاملة من وثائق السياسات المصاحبة لهذه السياسة الجامعة لأمن المعلومات.

يتم تحديد كل من هذه السياسات والاتفاق عليها من قبل شخص واحد أو أكثر ممن يمتلكون الكفاءة في المجال ذي الصلة، وبمجرد اعتمادها رسمياً، يتم توصيلها إلى الجمهور المناسب، سواء داخل البنك أو خارجه.

يوضح الجدول التالي السياسات الفردية ضمن مجموعة الوثائق ويلخص محتوى كل سياسة والجمهور المستهدف، مع إشارة إلى مدى ارتباطها المباشر بالفجوات والحوادث الموثقة في دراسة حالة بنك الأفاق الرقمية:

عنوان السياسة	المجالات التي تغطيها	الجمهور المستهدف
سياسة التحكم في الوصول	تسجيل المستخدمين وإلغاء تسجيلهم، منح صلاحيات الوصول، المراجعة الدورية للصلاحيات، سياسة كلمات المرور، ضوابط الوصول للأنظمة والتطبيقات.	جميع الموظفين وأقسام تقنية المعلومات

عنوان السياسة	المجالات التي تغطيها	الجمهور المستهدف
سياسة إدارة كلمات المرور المميزة	إدارة وتخزين وتدوير كلمات مرور حسابات المسؤولين والأنظمة الحساسة.	مسؤولو الأنظمة والشبكات وقواعد البيانات
سياسة تشفير البيانات	تقييم المخاطر واختيار تقنيات التشفير، إدارة مفاتيح التشفير، تشفير الأقراص الصلبة للأجهزة المحمولة.	فرق تقنية المعلومات وأمن المعلومات
سياسة الأمن المادي	تأمين المناطق الحساسة (مراكز البيانات، الفروع)، أمن المعدات، دورة حياة الأجهزة.	جميع الموظفين، خاصة العاملين بمركز البيانات والفروع
سياسة مكافحة البرمجيات الخبيثة	جدران الحماية، مكافحة الفيروسات، تصفية الرسائل المزعجة، إدارة الثغرات، التوعية، إدارة حوادث البرمجيات الخبيثة.	فرق العمليات الأمنية (SOC) وتقنية المعلومات
سياسة النسخ الاحتياطي	دورات النسخ الاحتياطي، النسخ السحابي، التخزين خارج الموقع، اختبار الاسترجاع.	فرق قواعد البيانات والبنية التحتية
سياسة التسجيل والمراقبة	إعدادات جمع الأحداث، حمايتها، ومراجعتها.	فرق العمليات الأمنية
سياسة إدارة الثغرات التقنية	تعريف الثغرات، مصادر المعلومات، التصحيحات والتحديثات، التقييم، التحسين، التوعية.	فرق أمن المعلومات وتقنية المعلومات
سياسة أمن الشبكات	تصميم أمن الشبكة، التقسيم، أمن المحيط، الشبكات اللاسلكية، الوصول عن بُعد، إدارة التغييرات.	فرق الشبكات وأمن المعلومات
سياسة المراسلات الإلكترونية	إرسال واستقبال الرسائل الإلكترونية، المراقبة، الاستخدام الآمن للبريد الإلكتروني.	جميع مستخدمي البريد الإلكتروني
سياسة التطوير الآمن	متطلبات الأعمال، تصميم الأنظمة، التطوير والاختبار، التطوير الخارجي.	فريق تطوير البرمجيات (25 مطوراً) والشركة الخارجية المتعاقدة
سياسة أمن المعلومات لعلاقات الموردين	العناية الواجبة، اتفاقيات الموردين، المراقبة والمراجعة، التغييرات والمنازعات.	الموظفون المسؤولون عن إدارة الموردين (AWS)، شركة تطوير التطبيق، شركات النقد والأمن
سياسة إدارة التوافر	متطلبات التوافر والتصميم، المراقبة والتقارير، عدم التوافر، اختبار الخطط.	فرق البنية التحتية وتقنية المعلومات

عنوان السياسة	المجالات التي تغطيها	الجمهور المستهدف
سياسة الاحتفاظ بالسجلات وحمايتها	مدة الاحتفاظ بأنواع السجلات، استخدام التشفير، اختيار الوسائط، الاسترجاع والإتلاف.	الموظفون المسؤولون عن إنشاء وإدارة السجلات (المالية، القانونية، الموارد البشرية)
سياسة الخصوصية وحماية البيانات الشخصية	التشريعات المعمول بها، التعريفات والمتطلبات.	الموظفون المسؤولون عن تصميم وإدارة الأنظمة التي تعالج بيانات شخصية
سياسة المكتب النظيف والشاشة النظيفة	أمن المعلومات المعروضة على الشاشات، المطبوعة، أو المحفوظة على وسائط قابلة للإزالة.	جميع الموظفين في المقر الرئيسي والفروع
سياسة أمن الموارد البشرية	التوظيف، عقود العمل، الامتثال للسياسات، الإجراءات التأديبية، إنهاء الخدمة.	جميع الموظفين وإدارة الموارد البشرية
سياسة الاستخدام المقبول	التزام الموظف بسياسات أمن المعلومات في المؤسسة.	جميع الموظفين
سياسة إدارة الأصول	قواعد إدارة الأصول من منظور أمن المعلومات.	جميع الموظفين وأصحاب الأصول
سياسة الدوائر التلفزيونية المغلقة (CCTV)	استخدام كاميرات المراقبة في الأمن المادي، مواقع التركيب، واعتبارات حماية البيانات.	الموظفون المسؤولون عن أنظمة المراقبة
سياسة إدارة التكوين	التكوين الآمن للأجهزة والبرمجيات والخدمات والشبكات.	الموظفون المسؤولون عن تصميم الأنظمة
سياسة الاستخبارات التهديدية	جمع واستخدام معلومات التهديدات على المستويات الاستراتيجية والتكتيكية والتشغيلية.	فرق العمليات الأمنية وتقييم المخاطر
سياسة الإبلاغ عن المخالفات في أمن المعلومات	آلية رفع القضايا المتعلقة بأمن المعلومات داخل المؤسسة.	جميع الموظفين والأطراف المعنية الأخرى

Table 1: Set of policy documents

2.5 تطبيق سياسة أمن المعلومات

تمت مراجعة واعتماد البيانات الواردة في هذه الوثيقة ومجموعة السياسات الداعمة المذكورة في الجدول أعلاه من قبل الإدارة العليا لبنك الأفاق الرقمية (الرئيس التنفيذي ومجلس الإدارة)، ويجب الالتزام بها من قبل جميع الموظفين وأصحاب العلاقة.

عدم التزام أي موظف بهذه السياسات قد يؤدي إلى اتخاذ إجراء تأديبي وفقاً لإجراء التأديب الوظيفي المعتمد لدى البنك.

يجب توجيه أي استفسارات بخصوص أي سياسة من سياسات بنك الأفاق الرقمية في المقام الأول إلى المدير المباشر للموظف، أو إلى إدارة أمن المعلومات (فريق حوكمة أمن المعلومات) للاستفسارات ذات الطابع الفني أو المتخصص.

يجب مراجعة هذه السياسة سنوياً كجزء من دورة مراجعة شاملة تغطي أيضاً الوثائق الرئيسية الأخرى مثل تقييم المخاطر وخطة التدريب، وينبغي أن تشمل هذه المراجعة مشاركة فعالة من إدارات الأعمال لضمان التقاط أي متطلبات متغيرة والحصول على تغذية راجعة من العملاء والجهات الرقابية (ساما وسدايا).